PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurisation d'OpenSSH

03-370 ANSSI - Recommandations pour un usage sécurisé d'OpenSSH — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le protocole SSH corrige les déficiences de FTP, TELNET, RSH et RCP en assurant l'authentification, l'intégrité et la confidentialité.
2. Pour le chiffrement du canal, le mode CTR est à utiliser car il s'affranchit des vulnérabilités du mode CBC.
3. L'utilisation d'une IGC OpenSSH permet de signer des certificats hôtes ou utilisateurs avec une propre clé privée sans utiliser le format X509.

Présentation et usages de SSH

Notion	À retenir
Le protocole	SSH corrige les déficiences de **FTP**, **TELNET**, **RSH** et **RCP** (authentification, intégrité, confidentialité). Utiliser uniquement la **version 2** via `Protocol 2` dans `sshd_config`.
Les usages	Remplacer **TELNET**, **RSH**, **RLOGIN** (accès shell) et **RCP**, **FTP** (transfert de fichiers via **SCP** ou **SFTP**). Tunnels SSH réservés aux protocoles sans sécurité robuste (**X11**, **VNC**).

Bonnes pratiques cryptographiques OpenSSH

Notion	À retenir
Authentification serveur	Vérifier l'empreinte de la clé publique ou un certificat valide via l'attribut `StrictHostKeyChecking` de `ssh_config`.
Génération des clés	**RSA ≥ 2048 bits**, **ECDSA ≥ 256 bits** (préféré à RSA). **DSA** non recommandé (**1024 bits** insuffisant).
Aléa et diffusion	Source d'aléa fiable (machine physique privilégiée). Clé privée protégée par mot de passe en **AES-128 mode CBC**. Permissions : **root** pour clé hôte, **utilisateur** pour clé utilisateur.
Algorithmes symétriques	Chiffrement : **AES 128, 192 ou 256** en mode **CTR**. Intégrité : **HMAC SHA-1, SHA-256 ou SHA-512**. Préférer **encrypt-then-mac**.

Précisions techniques et versions

- **Durée de vie** : les tailles de clés sont calculées pour une durée de vie estimée de **trois ans** de l'hôte.
- **Machines virtuelles** : elles souffrent d'un déterminisme réduisant l'entropie disponible par rapport aux machines physiques.
- **Obsolescence 3DES** : le mode **3DES** est obsolète pour protéger le mot de passe depuis la version **5.3**.
- **Évolution mode MAC** : le mode **encrypt-then-mac** est préféré au **mac-then-encrypt** depuis la version **6.3**.
- **Vulnérabilité CBC** : le mode **CTR** est à utiliser pour le chiffrement du canal car il s'affranchit des vulnérabilités du mode **CBC**.

Durcissement du système et des accès

Notion	À retenir
Séparation de privilèges	Utiliser le **sandboxing** (depuis version **5.9**) et le `ChrootDirectory` (partition isolée, `nodev`, `noexec`, `nosuid`) pour le SFTP.
Authentification	Ordre : **ECDSA**, **RSA**, **GSSAPI** (Kerberos), **PAM** (sans exposition), puis **mot de passe** (proscrit pour privilèges élevés).
Agent et imputabilité	**Agent forwarding** pour un rebond, via un **hôte relais de confiance** (il sollicite l'agent sans voir la clé). Compte unique/incessible. `PermitRootLogin no`. Restriction via `AllowUsers` ou `AllowGroups`.
Restriction environnement	Bloquer l'altération via `PermitUserEnvironment no`. Variables via `AcceptEnv`. Commandes limitées via `ForceCommand`, `authorized_keys` ou `sudo`.

Résumé de l'accès et de la gestion des clés

Notion	À retenir
Écoute réseau	Écouter sur une **adresse d'administration** séparée. Si réseau non maîtrisé : port ≠ **22**, de préférence **< 1024**. `AllowTcpForwarding no`, `X11Forwarding no` sauf besoin justifié.
Infrastructure IGC	Utiliser l'IGC (depuis **v5.4**) **non X509**, sans chaîne de certification (AC créée via `ssh-keygen`). Autorités (hôte/utilisateur) avec **mot de passe robuste**. Validité : **3 ans**.
Enregistrements SSHFP	Publication des empreintes via **SSHFP** (**RFC 4255**). Nécessite **DNSSEC** pour être sécurisé ; reste un **indicateur complémentaire**.

Pièges et confusions

- ⚠ Utiliser l'agent forwarding via un relais non fiable : il ne voit pas la clé privée mais peut solliciter l'agent.
- ⚠ Considérer un décalage entre l'empreinte du serveur sshd et celle du DNS comme une simple erreur de configuration plutôt qu'un incident de sécurité critique.
- ⚠ Oublier que ne pas authentifier le serveur permet une attaque de l'homme du milieu pour récupérer l'intégralité du flux.
- ⚠ Utiliser le mode 3DES pour protéger le mot de passe.
- ⚠ Confondre le mode encrypt-then-mac avec le mode mac-then-encrypt qui est moins préféré.
- ⚠ Penser que les machines virtuelles offrent une meilleure entropie que les machines physiques.

Sigles et définitions

SSH	Protocole applicatif de couche 7 corrigeant les déficiences de FTP, RSH, RCP et TELNET.
OpenSSH	Implémentation de référence de SSH composée d'un serveur sshd, de clients ssh, scp et sftp.
TOFU	Modèle demandant confirmation à l'utilisateur lors de la première connexion à un hôte inconnu.
Chroot	Technique confinant un utilisateur SFTP dans une arborescence de fichiers isolée via l'option ChrootDirectory.
Agent Forwarding	Mécanisme permettant à un hôte relais de rediriger les requêtes d'authentification vers l'agent du poste client.
IGC OpenSSH	Infrastructure spécifique à SSH, non conforme au format X509, utilisant une autorité de certification propre.
SSHFP	Enregistrement DNS stockant l'empreinte d'une clé hôte SSH, normalisé par la RFC 4255.

Auto-test

1. Quelle est la taille minimale recommandée pour une clé RSA ?
2. Quel mode de chiffrement est préféré pour s'affranchir des vulnérabilités du mode CBC ?
3. Quelle option permet de confiner un utilisateur SFTP dans une arborescence isolée ?
4. Quelle est la durée de vie estimée pour le calcul des tailles de clés ?
5. Quel algorithme est préféré à RSA pour la génération de clés ?

Réponses : **1.** 2048 bits · **2.** Le mode CTR · **3.** ChrootDirectory · **4.** 3 ans · **5.** ECDSA

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.